ВНУТРЕННИЙ АУДИТ ИНФРАСТРУКТУРЫ · READ-ONLY

Аудит периметра 360pro / omicron

Админ-учётки и порты по ~80 узлам (домены flash · omicron · omiplat · rocket · rtc). Метод: SSH-ключ, внешние пробы портов с VPN и pivot fwatcher. 07–14.09.2026.

тема: авто

81
узлов в инвентаре

11
критических

39
высокой важности

15
на EOL-ОС

21
без доступа к ОС

01 Сквозные проблемы

повторяются по многим узлам — устранять централизованно

S1 Бэкапы БД не работают

db-backup1/2 (160.135/136): каталоги /db-backups пусты — резервных копий БД по факту нет.

S2 omicron-sudo = NOPASSWD: ALL

Полный root без пароля по всему парку; группа раздута до 16 членов, забита nologin ex-staff + внешними подрядчиками.

S3 ActiveMQ CVE-2023-46604

RCE 10.0 на всех 5 bg-core, OpenWire 61616 в сети, java от root.

S4 Внешние подрядчики с root

valeriy@bgbilling.ru, sgaregin@example.com, avk@it-solution.ru, atarasov@cc.ru — sudo/docker на git, voice, bitrix-to-erp, call-центрах.

S5 docker + ansible = privesc

ansible в группе docker при активном docker = root на ~12 узлах; ufw не фильтрует docker-published порты.

S6 **Нет хостового фаервола**

nftables/firewalld/ufw неактивны почти везде. Единственный эталон — speedtest (161.48).

S7 **СУБД и admin-интерфейсы в сети**

ProxySQL 6032, MySQL/PG/Redis/Mongo, mysqld_exporter, Zabbix/Prometheus/Alertmanager без auth.

S8 **EOL-ОС**

Debian 11 (все bg-*, ProxySQL, DNS, erp), CentOS 7 (call-center), vCenter 6.7 — без патчей безопасности.

S9 **fail2ban выключен точечно**

prometheus (выкл), bitrix / callcenter-deb2 / CALLCENTERFLASH (в состоянии failed).

S10 **unattended-upgrades почти нигде**

Включён лишь на speedtest, wiki2, bitrix-to-erp. Отставание 130–260 security-обновлений на узел.

S11 **'debian' и nologin в sudo**

Установочная учётка debian в native sudo на Debian 13-хостах; ex-staff nologin в omicron-sudo повсеместно.

S12 **Экспортеры без ограничений**

node_exporter (9100) и zabbix-agent (10050) без ограничения Server= почти на каждом хосте.

02 Инвентарь узлов показано 81 из 81

ВАЖН.	АДРЕС / ХОСТ	КЛАСС	ДОСТУП	КЛЮЧЕВАЯ НАХОДКА
КРИТ	**192.168.110.7**	A · BGBilling ядро	read-only	ActiveMQ 5.15.5 CVE-2 46604 (61616 наружу world-writable платёж JSP; /opt/dump.sql чи TFTP 0777; Debian 11
КРИТ	**192.168.160.101**	A · BGBilling ядро	read-only	ActiveMQ 5.18.1 уязви (61616/STOMP/MQTT/ наружу); java от root; Debian 11 EOL

ВАЖН.	АДРЕС / ХОСТ	КЛАСС	ДОСТУП	КЛЮЧЕВАЯ НАХОДКА
КРИТ	**192.168.160.54**	A · BGBilling ядро	read-only	ActiveMQ 5.15.5; Wildl mgmt 9990 в сети; 22 обновлений; Debian 1
КРИТ	**172.16.100.24**	A · BGBilling ядро	read-only	ActiveMQ 5.17.3 уязви CVE-2023-46604; бро наружу; Debian 11 EO
КРИТ	**192.168.160.87**	A · BGBilling ядро	read-only	ActiveMQ 5.17.3 уязви 194 обновления; Debi EOL
КРИТ	**192.168.161.7**	I · Docker web	read-only	Docker Registry 5000 АНОНИМЕН по сети (/v2/_catalog отдаёт репозитории); вендор valeriy+sgaregin с root docker активен
КРИТ	**192.168.161.12**	I · Docker web	read-only	Squid 3128 ОТКРЫТЫ прокси + SOCKS 1080 MySQL/PG/Redis/Mon Vite dev-серверы в се (~27 контейнеров)
КРИТ	**192.168.160.104**	J · Мониторинг	read-only	Zabbix веб+server 100 наружу → RCE на все хостах с агентом; omi sudo 16 членов (макс
КРИТ	**192.168.160.135**	M · Бэкапы	read-only	СЕРВЕР БЭКАПОВ БД каталоги /db-backups ПУСТЫ (при 689G зан — бэкапы БД не складываются
КРИТ	**192.168.160.136**	M · Бэкапы	read-only	второй бэкап-сервер (2.5G/491G) — бэкапо по факту НЕТ (систем проблема)
КРИТ	**192.168.160.31**	M · ERP	NOPASSWD root	дампы БД ERP в /opt readable (читаемы rea only юзером); MySQL+mysqld_expor сети; Debian 11 EOL
ВЫСОК	**192.168.110.8**	B · RADIUS/BGInet	read-only	BGInet 1951 — управляющая консол auth; RADIUS 1812/18 наружу; java от root; D 11 EOL

ВАЖН.	АДРЕС / ХОСТ	КЛАСС	ДОСТУП	КЛЮЧЕВАЯ НАХОДКА
ВЫСОК	**192.168.160.102**	B · RADIUS/BGInet	read-only	1951 без auth; RADIU наружу; дубль aglukhov/agluchov в su
ВЫСОК	**192.168.160.55**	B · RADIUS/BGInet	read-only	1951 без auth; RADIU наружу; дубль-опечат учётки в sudo
ВЫСОК	**172.16.100.27**	B · RADIUS/BGInet	read-only	1951 без auth; RADIU наружу; 151 обновле
ВЫСОК	**192.168.160.88**	B · RADIUS/BGInet	read-only	1951 без auth; RADIU наружу; 173 обновле
ВЫСОК	**192.168.110.20**	C · ProxySQL	read-only	ProxySQL admin 6032 сети (креды БД билли Debian 11 EOL
ВЫСОК	**192.168.160.103**	C · ProxySQL	read-only	admin 6032 в сети; omicron-sudo ~8 nolog Debian 11 EOL
ВЫСОК	**192.168.160.89**	C · ProxySQL	read-only	admin 6032/client 6033/web 6080 в сети Debian 11 EOL
ВЫСОК	**192.168.161.172**	D · API-шлюз	read-only	api.flash-telecom.ru → BGBilling 110.7 по HT (платежи Сбербанк/TV/mob)
ВЫСОК	**192.168.161.173**	D · API-шлюз	read-only	api/lk/mob.omiplat.ru BGBilling; stub_status без auth; PII-executer наружу
ВЫСОК	**192.168.161.175**	D · API-шлюз	read-only	api/lk.rocket-telecom.r BGBilling 160.87; stub_status 8098 без а
ВЫСОК	**192.168.161.176**	D · API-шлюз	read-only	api/lk/mob.omicron.on → BGBilling 160.101; rate-limit (лучше проч
ВЫСОК	**192.168.160.35**	E · Call-центр	NOPASSWD root	CentOS 7 EOL; firewall Asterisk AMI 5038 + M в сети; omicron-sudo внешним atarasov@co
ВЫСОК	**192.168.160.219**	E · Call-центр	read-only	ITGRIX; нет хостового фаервола; MariaDB в fail2ban упал
ВЫСОК	**192.168.110.29**	E · Call-центр	read-only	AMI 5038 + MySQL в с ufw пропускает лишн

ВАЖН.	АДРЕС / ХОСТ	КЛАСС	ДОСТУП	КЛЮЧЕВАЯ НАХОДКА
				fail2ban упал
ВЫСОК	**192.168.160.217**	E · Call-центр	read-only	AMI 5038 в сети; 219 обновлений; MySQL н localhost (плюс)
ВЫСОК	**172.16.100.54**	E · Call-центр	read-only	AMI 5038 в сети; 219 обновлений
ВЫСОК	**192.168.110.30**	E · Call-центр	read-only	MySQL 3306 И AMI 50 сети; 218 обновлений
ВЫСОК	**192.168.161.13**	E · Call-центр	read-only	AMI 5038 в сети; omic sudo с двумя внешни (atarasov+sgaregin)
ВЫСОК	**192.168.161.33**	F · Почта	read-only	ДВУХДОМНЫЙ: интер нога 155.x + внутренн 161.x = мост периметр↔внутрь; ор relay?
ВЫСОК	**192.168.161.18**	G · DNS PowerDNS	read-only	PowerDNS; MySQL зон API 8080/8081 в сегм docker+ansible=prives Debian 11 EOL; только через pivot
ВЫСОК	**192.168.161.19**	G · DNS PowerDNS	read-only	реплика ns1: MySQL+. сегменте; docker=priv Debian 11 EOL
ВЫСОК	**192.168.161.15**	I · Docker web	read-only	ejabberd XMPP 5222 в docker активен + ansi живой privesc
ВЫСОК	**192.168.160.119**	I · Docker web	read-only	PostgreSQL 5432 опубликован docker наружу (ufw не защищ проверить auth n8n (F ноды)
ВЫСОК	**192.168.160.45**	J · Мониторинг	NOPASSWD root	Prometheus 9090 + Alertmanager 9093 БЕ аутентификации; fail2 выключен; 158 обновлений
ВЫСОК	**192.168.160.68**	J · Сеть/NOC	read-only	Observium+RANCID (к всех сетевых устройс vsftpd PLAIN FTP нару
ВЫСОК	**192.168.161.135**	K · Фаервол	нет	OPNsense (FreeBSD) фаервол + ntopng; GU HTTP:80; своя база — нужен админ OPNsen

ВАЖН.	АДРЕС / ХОСТ	КЛАСС	ДОСТУП	КЛЮЧЕВАЯ НАХОДКА
ВЫСОК	**192.168.161.26**	K · VPN/AAA	NOPASSWD root	VPN-шлюз; веб-порта управления VPN (gunicorn/python) от R сети — проверить aut
ВЫСОК	**192.168.161.100**	K · VPN/AAA	read-only	MFA RADIUS-адаптер inebalzin (ex-staff) в НАТИВНОЙ группе su ufw активен: 198

поиск: IP, имя хоста, находка | крит | высок | средн | ок | нет доступа

				(1723) ВКЛЮЧЁН (устаревший); mgmt-r (RDP/WinRM/SMB) нар
ВЫСОК	**192.168.161.96**	K · VPN/AAA	read-only	TACACS+ — админ-до ко ВСЕМ сетевым устройствам; 205 обновлений; огранич :49
ВЫСОК	**192.168.161.17**	L · Голос.аналитика	NOPASSWD root	Postgres/Redis голосо данных в сети; вендо valeriy+sgaregin с root sgaregin в docker
ВЫСОК	**192.168.161.45**	L · Голос.аналитика	read-only	близнец voice1: БД в вендор valeriy+sgareg root; sgaregin в docker обновлений
ВЫСОК	**192.168.160.110**	M · Битрикс24	NOPASSWD root	CentOS 9; omicron-sudo=NOPASSWD ALL ПОДТВЕРЖДЁН; fail2 упал ~5 мес; MySQL н интерфейсах
ВЫСОК	**192.168.161.49**	M · Интеграция	read-only	внешний подрядчик avk@it-solution.ru с su десктоп GNOME на сервере; интеграция развёрнута
ВЫСОК	**192.168.161.55**	M · Инфра/pivot	NOPASSWD root	Flussonic Watcher 26.(PIVOT в сегмент 161.: (Exchange); Watcher API/RTSP наружу
ВЫСОК	**192.168.160.11**	M · Сеть/хранилище	нет	конфиги Mikrotik + ша key; анонимная SMB-энумерация шар (чте запрещено)
ВЫСОК	**192.168.160.202**	O · VMware	нет	vCenter 6.7 EOL; mgm 443/5480/9443/22 на

ВАЖН.	АДРЕС / ХОСТ	КЛАСС	ДОСТУП	КЛЮЧЕВАЯ НАХОДКА
				нужны кред SSO
ВЫСОК	**172.16.100.45**	P · Биллинг/DPI	нет	платформа SCAT; TLS- scat.test ПРОСРОЧЕН; пароль включён; клю подходит
СРЕДН	**192.168.160.70**	C · ProxySQL	read-only	admin 6032 отфильтр с mgmt-VPN; ТЕСТ-ак gmasich-test1 в sudo
СРЕДН	**192.168.161.174**	D · API-шлюз	read-only	НЕ настроен (conf.d п только дефолт nginx) заготовка
СРЕДН	**192.168.161.11**	E · Телефония	read-only	FOP2 веб только по H (без TLS); демон 4445 сети
СРЕДН	**192.168.161.8**	E · Удал.доступ	read-only	RustDesk-сервер; проверить принудительность кл (не открытый ли реле портал по HTTP
СРЕДН	**192.168.161.32**	F · Почта	read-only	Postfix+SOGo, мульти- проверить open-relay AUTH/TLS на 587/465
СРЕДН	**192.168.161.110**	H · Kubernetes	read-only	control-plane (6443/10250/etcd) на но с auth/mTLS; docke активен=privesc; пропатчен
СРЕДН	**192.168.161.120**	H · Kubernetes	read-only	control-plane наружу (auth; docker не запущ обновлений
СРЕДН	**192.168.161.130**	H · Kubernetes	read-only	control-plane наружу (auth; docker не запущ обновлений
СРЕДН	**192.168.161.140**	H · Kubernetes	read-only	4-й server etcd — чётн кворум (пересмотрет auth/mTLS ок
СРЕДН	**192.168.161.5**	I · Docker web	read-only	NetBox 8080 (auth включена); БД внутри docker; ansible+docker=prives
СРЕДН	**192.168.160.100**	I · Docker web	read-only	wiki за nginx (403 на I unattended ВКЛЮЧЁН docker+ansible=prives

ВАЖН.	АДРЕС / ХОСТ	КЛАСС	ДОСТУП	КЛЮЧЕВАЯ НАХОДКА
СРЕДН	**192.168.160.19**	J · Мониторинг	NOPASSWD root	Grafana 13 (auth включ по HTTP; docker активе ansible = privesc; 0 обновлений
СРЕДН	**192.168.161.4**	L · Голос.аналитика	read-only	ops-узел, экспозиция минимальна (0 обновлений); но valeriy/sgaregin в sudo
СРЕДН	**192.168.161.56**	M · Инфра	NOPASSWD root	заявлен как стример, пустой (клон шаблона omicron-sudo=NOPAS 3 nologin
СРЕДН	**192.168.160.6**	N · Веб (ASP.NET)	нет	nginx→ASP.NET, вали TLS, форс-HTTPS, лог SSH нет — аудит ОС невозможен
СРЕДН	**192.168.160.215**	N · Веб (SPA)	нет	приложение Katan; se signed TLS; 80 без редиректа; SSH нет
ОК	**192.168.161.48**	N · Веб-сервис	read-only	ЭТАЛОН гигиены: nfta АКТИВЕН (единствен + unattended включён обновлений
Н/Д	**bit.360pro.online**	— Мёртвая DNS	нет	DNS-запись указывае выключенный/ несуществующий 161 (dangling)
Н/Д	**192.168.160.2**	— Недоступно	нет	жив, но все порты закрыты/фильтрован вероятно шлюз/фаер без mgmt в сегменте
Н/Д	**185.221.44.3**	— Недоступно	нет	публичный адрес; пингуется, портов нет принадлежность не подтверждена
Н/Д	**192.168.110.17**	— Нет доступа	нет	Debian 12, только SSH:1221 (publickey+password); mpeshkov не заведён
Н/Д	**192.168.161.71**	— Нет доступа	нет	Debian 12, только SSH:1221; ключ не заведён; вход по паро включён

ВАЖН.	АДРЕС / ХОСТ	КЛАСС	ДОСТУП	КЛЮЧЕВАЯ НАХОДКА
Н/Д	**192.168.161.72**	— Нет доступа	нет	Debian 12, только SSH:1221; ключ не за
Н/Д	**192.168.110.110**	— Нет доступа	нет	Debian 11 EOL, только SSH:22; ключ не заве пароль включён
Н/Д	**172.16.100.25**	— Нет доступа	нет	Debian 12, только SSH:1221; ключ mpes не заведён (rocket-сегмент)
Н/Д	**192.168.155.253**	— DMZ/периметр	нет	Ubuntu+Apache в сегм 155.x (интернет); вне omicron-парка; ключ подходит; веб HTTP
Н/Д	**172.16.100.26**	C · ProxySQL	нет	ключ mpeshkov не заведён; ProxySQL ad 6032 открыт снаружи
Н/Д	**192.168.160.21**	O · VMware	нет	vCenter — ВЫКЛЮЧЕН (100% потерь пинга)
Н/Д	**192.168.160.22**	O · VMware?	нет	выключен; PTR нет; р с vcsa
Н/Д	**192.168.160.113**	P · Windows	нет	Windows NPS (RADIUS сет.политики); RDP/WinRM/SMB; нуж доменные кред
Н/Д	**192.168.160.46**	P · Windows	нет	Power BI + MS SQL/My WinRM; нужны домен кред

03 Приоритеты

Топ критических точек

01 db-backup1/2 — бэкапы БД не складываются
бизнес-риск: восстанавливаться не из чего

02 GitLab 161.7 — анонимный Docker Registry 5000
исходники и секреты доступны по сети без auth

03 sv1 161.12 — открытый Squid-прокси + все СУБД в сеть
анонимизация/пивот + MySQL/PG/Redis/Mongo

04 zabbix-core 160.104 — веб+server наружу

RCE на всех хостах с агентом

05 **erp/BGERP 160.31 — дампы БД ERP world-readable**
утечка бизнес-данных «в покое»

06 **bg-core ×5 — ActiveMQ CVE-2023-46604**
61616 наружу, java от root

07 **oms + samba + tacacs — ключи от сетевого оборудования**
RANCID/конфиги Mikrotik/TACACS+ + plain FTP

08 **omicron-sudo=NOPASSWD с ex-staff и подрядчиками**
по всему парку — единая точка отказа

09 **bg-core-flash 110.7 — платёжные JSP world-writable**
+ dump.sql + TFTP 0777

10 **msVPN 160.118 — PPTP включён**
устаревший VPN-протокол на периметре

Первоочередной план

A Восстановить бэкапы БД — проверить задания на всех СУБД-серверах (сегодня)

B Закрыть анонимный Docker Registry (161.7) и открытый Squid/SOCKS (161.12)

C Ревизия omicron-sudo: убрать nologin, тест-акк, вынести внешних подрядчиков; отменить NOPASSWD

D Обновить ActiveMQ на bg-core + закрыть 61616/брокер фаерволом

E СУБД/admin-интерфейсы с 0.0.0.0 → localhost; DOCKER-USER для docker-портов

F Мониторинг (Zabbix/Prometheus/Alertmanager) за auth/reverse-proxy/фаервол

G Вынести ansible из группы docker на активных docker-хостах

H Развернуть nftables (как на speedtest) и unattended-upgrades по парку

I План миграции с Debian 11 / CentOS 7 / vCenter 6.7 (EOL)

J Точечно: 110.7 JSP/dump/TFTP · oms FTP · msVPN PPTP · erp дампы · починить fail2ban · серты